

# Privacy Policy Draft

**Status:** Draft for legal review

**Purpose:** Technical/product draft describing the data processing implemented by the current Elderly Monitoring System.

**Important:** This document is not legal advice. It is an implementation-based draft for review and completion by the organisation operating the service and qualified legal counsel before publication.

## 1. Overview

The Elderly Monitoring System is a non-intrusive home-monitoring application intended to help families and caregivers identify possible changes in an elderly person's normal household routine.

The current implementation uses electricity-consumption and connectivity information from configured Wi-Fi smart plugs connected through the Tuya ecosystem. Smart-plug telemetry is collected through the Tuya Cloud API, stored in PostgreSQL, processed into activity and routine signals, displayed through an authenticated web dashboard, and used by the alerting service to send configured notifications.

A core design rule is that **missing telemetry is not treated as evidence of inactivity**. Device connectivity and data freshness are evaluated separately from activity inference. When the system cannot rely on sufficiently fresh data, it reports a system/data condition instead of presenting an activity conclusion.

The system is a monitoring and notification tool. It does not directly observe a person's physical condition and does not provide a medical diagnosis.

## 2. Data Controller

- **Controller:** [LEGAL NAME / COMPANY NAME]
- **Address:** [ADDRESS]
- **Privacy email:** [PRIVACY EMAIL]
- **Website:** [WEBSITE, IF APPLICABLE]
- **DPO / privacy contact:** [IF APPLICABLE]

These details must be completed by the organisation responsible for the service.

## 3. What the Current System Processes

### 3.1 Smart-plug and electricity telemetry

For each configured smart plug, the collector can receive and store:

- Tuya device identifier;
- configured device name;
- configured room;
- instantaneous power consumption;
- electrical current;
- electrical voltage;
- switch state;
- authoritative device online/offline status;
- timestamp of the reading;
- energy increment reported by the device;
- accumulated energy maintained by the application.

The collector normally polls configured devices approximately every 60 seconds. The exact interval can be changed by deployment configuration.

Tuya values such as power and voltage are converted into application units when they are ingested. Energy increments are accumulated by the application rather than treated as an already accumulated lifetime total.

### 3.2 Device connectivity and data-freshness information

The system separately tracks device connectivity. A failed poll or an authoritative offline status first places a device into a suspected-offline state. Short interruptions are not immediately treated as confirmed outages.

After the configured offline tolerance is exceeded, the system records a confirmed offline event. When connectivity is restored, a return-to-online event is recorded.

The dashboard also evaluates the freshness of the newest available reading. If data is older than the residence's configured staleness threshold, the system can present a SYSTEM / no-data condition rather than calculating an activity verdict from stale information.

### 3.3 Activity and routine inferences

The inference layer processes power readings to identify activity events. Events are based on readings above configured per-device wattage thresholds and are de-duplicated.

From usable activity signals, the system can derive:

- activity probability by hour;
- typical and maximum gaps between activity events;
- habitual quiet hours;
- peak activity hours;
- recent activity;
- daily event counts;
- current GREEN, YELLOW or RED activity states;
- SYSTEM states representing data/connectivity conditions;
- day-by-day validation results, including GREEN, YELLOW, RED and SEM DADOS.

Low-signal devices, such as devices whose normal power signature is not useful for activity inference, can be excluded from activity inference while continuing to be monitored for connectivity.

These outputs are **inferences from electricity and device telemetry**. They are not direct measurements of a person's movement, location, consciousness, health, or medical condition.

The current implementation learns from the available historical data and excludes known data gaps from learning. It does not represent the absence of a reading as a quiet period. The current implementation should not be described as guaranteeing a fixed minimum number of learning days before every inference is shown; any minimum-learning-period requirement must be added and documented separately if adopted.

### 3.4 Residence and monitoring configuration

The system stores residence-level information and settings needed to operate monitoring, including:

- residence name;
- time zone;
- creation information;
- alert and sensitivity settings;
- data-staleness threshold;
- offline tolerance;
- optional manual silence ceiling;
- other configured monitoring thresholds.

### 3.5 User account and authentication information

The web application stores account information needed for authentication and access control, including:

- username;
- bcrypt password hash;
- role;
- residence association;
- display name;
- account creation time.

The current roles are **caregiver** and **administrator**. Caregiver access is scoped to the relevant residence, while administrators can manage broader monitoring settings.

The application uses server-side sessions. The browser receives an HTTP-only, SameSite authentication cookie. The current implementation documents server-side session expiration of one week.

### 3.6 Alert contacts

Configured notification contacts can include:

- contact name;
- email address;
- WhatsApp phone number;
- notification tier;
- active/inactive status;
- creation time.

These details are used to determine where configured monitoring notifications are sent.

### 3.7 Notification processing and history

The alerting service periodically evaluates the current system state and compares it with the previously notified state. The intended behaviour is to notify on state changes rather than repeatedly sending the same unchanged notification.

Current notification rules are:

- **YELLOW / routine warning:** email to configured all-tier contacts;
- **return to GREEN:** email to configured all-tier contacts;
- **RED activity:** WhatsApp and email to configured contacts when those channels are configured;
- **SYSTEM / confirmed offline condition:** WhatsApp and email to configured contacts when those channels are configured.

Notification history can record the residence, timestamp, channel, destination, notification tier, state, subject, outcome, and technical delivery details.

Email delivery uses the configured SMTP service. WhatsApp delivery uses the configured WhatsApp Business-compatible API/provider. If a channel is not configured, that channel does not send a notification.

### 3.8 Technical and operational logs

Application and infrastructure components can produce logs containing timestamps, service events, errors, authentication/operational events, and diagnostic information.

The exact content and retention of infrastructure logs can depend on the deployment, Docker configuration, hosting provider, and operational practices. The final policy should therefore identify the applicable logging and retention arrangements before publication.

## 4. Information the Current Application Does Not Intentionally Collect

The current application does not contain subsystems for:

- camera images or video;
- microphone/audio recordings;
- GPS or direct person-location tracking;
- heart-rate monitoring;
- blood pressure monitoring;
- blood glucose monitoring;
- medication records;
- facial recognition;
- direct medical diagnosis.

The system can nevertheless infer aspects of household activity or routine from electricity consumption. Therefore, the absence of cameras or microphones should not be interpreted as meaning that the system processes no information about household behaviour.

## 5. Why the System Processes the Data

The current implementation processes information for the following operational purposes:

1. collect and store smart-plug telemetry;
2. monitor device connectivity and data freshness;
3. learn household activity patterns from usable electricity signals;
4. identify deviations from the learned activity baseline;
5. keep connectivity/data failures separate from activity conclusions;
6. display live status, routine information, charts and reports;
7. generate and send configured notifications;
8. authenticate users and enforce residence/role-based access;
9. manage monitoring sensitivity and residence settings;
10. maintain, troubleshoot, secure and operate the application.

## 6. How the Data Flows Through the System

The current deployment consists of four Docker services:

**Smart plugs → Tuya Cloud API → Collector → PostgreSQL → Inference/Web/API → Dashboard and Alerting**

- **Collector:** polls configured Tuya devices, converts and stores telemetry, and records connectivity transitions.
- **PostgreSQL:** stores telemetry, device records, connectivity events, residence settings, accounts, contacts, and operational/notification records used by the application.
- **Inference:** derives activity events, routine baselines and GREEN/YELLOW/RED activity states from usable readings.
- **Web/API:** provides authenticated dashboard, state, reports and administrator settings.
- **Alerting:** periodically evaluates current state and sends configured email/WhatsApp notifications.

The documented deployment binds PostgreSQL to localhost rather than exposing the database directly to the public network.

## 7. Third-Party Services and External Processing

### 7.1 Tuya

The collector communicates with the Tuya Cloud API to authenticate the integration and obtain configured smart-device information and telemetry.

The controller should identify the applicable Tuya service terms, privacy documentation and data-processing arrangements before publication.

## 7.2 Email / SMTP provider

When email notifications are enabled, the application uses the configured SMTP provider. Depending on the provider, this can involve recipient addresses, sender information, message subjects and notification content.

**Provider:** [SMTP PROVIDER]

## 7.3 WhatsApp provider

When WhatsApp notifications are enabled, the application sends notification requests through the configured WhatsApp Business-compatible API/provider. This can involve recipient phone numbers and notification content or template information.

**Provider:** [WHATSAPP PROVIDER]

## 7.4 Hosting provider

The application is deployed on third-party VPS/cloud infrastructure. The hosting provider may therefore technically process or have infrastructure-level access to data stored or processed on the server, subject to the hosting arrangement and security controls.

**Provider:** [HOSTING PROVIDER]

The controller should document the relevant contracts, data-processing terms, processing locations and security responsibilities for each provider.

## 8. Who Can Access the Data

Access is controlled through the web application's authentication and role model.

- **Caregiver users:** access the monitoring dashboard for their associated residence.
- **Administrators:** can access broader administration and monitoring settings.
- **Application services:** access only the database information required for their functions.
- **Notification providers:** receive information necessary to deliver configured notifications.
- **Hosting/infrastructure providers:** may have technical access according to the hosting and administration arrangement.

The final policy should identify any additional human operators, support personnel, or contractors who may have access in the actual service operation.

## 9. Security Measures

The current implementation includes:

- bcrypt password hashing;
- server-side revocable sessions;
- HTTP-only/SameSite authentication cookies;
- role-based and residence-scoped access;
- authenticated access to monitoring data;
- sensitive configuration stored through environment variables rather than application source configuration;
- PostgreSQL bound to localhost in the documented deployment;
- Docker services configured to restart automatically after service/host restarts.

The deployment documentation recommends placing the web application behind HTTPS before real-world use.

Security is also dependent on the operator's VPS configuration, operating-system updates, Docker configuration, credentials, backups, network controls, access permissions and provider security.

## 10. Data Retention

**Retention periods:** [TO BE DEFINED BY THE CONTROLLER AND COUNSEL]

The current implementation stores telemetry and operational records in PostgreSQL but does not define a complete automatic retention/deletion schedule for every data category.

Before launch, the controller should define retention periods separately for, at minimum:

- raw device readings;
- device and residence records;
- connectivity events;
- inferred activity/routine information;
- user accounts and sessions;
- alert contacts;
- notification history;
- application/infrastructure logs;
- backups.

Retention should be based on the service purpose and applicable legal requirements rather than keeping all historical information indefinitely by default.

## 11. Deletion and Account Closure

**Deletion procedure:** [TO BE DEFINED]

The current application does not by itself establish a complete user-facing data-erasure workflow for every stored category.

Before publication, the controller should define how requests for deletion, correction or account closure are handled, including treatment of:

- user accounts;
- residence and device records;
- telemetry;
- connectivity events;
- inferred activity data;
- alert contacts;
- notification history;
- sessions;
- backups and archived copies.

## 12. Privacy and Data-Subject Requests

Depending on the applicable jurisdiction and legal basis, affected individuals may have rights such as access, correction, deletion, restriction, objection, portability, withdrawal of consent where applicable, and the right to complain to a competent data-protection authority.

**Privacy request contact:** [PRIVACY EMAIL]

The controller and legal counsel must determine which rights apply, who may exercise them, and the procedure and response periods.

### **13. Legal Basis and Consent**

**To be completed by the controller and legal counsel.**

The appropriate legal basis depends on the organisation operating the service, the jurisdiction, the relationship with monitored individuals, and the purpose of processing.

Because the system can generate inferences about household activity and possible wellbeing from electricity data, the controller should specifically assess whether any such processing is subject to additional privacy or sensitive-data requirements.

Where consent is relied upon, the controller should document how consent is obtained, recorded, withdrawn and communicated to affected individuals.

### **14. Automated Processing and Profiling**

The system automatically analyses smart-plug readings, establishes a residence/device activity baseline from available historical data, and may classify the current state as GREEN, YELLOW, RED or SYSTEM.

The current implementation uses rule-based processing and configurable thresholds rather than a medical diagnostic model.

These classifications are intended to support monitoring and notification. They should not be represented as a diagnosis, a confirmed emergency, or a definitive statement about a person's health or safety.

The controller and legal counsel should assess whether the processing constitutes profiling or automated decision-making under applicable law and whether additional safeguards or human review are required.

### **15. Household Members and Other People**

Smart-plug consumption can reflect activity by more than one person living in, visiting, or otherwise using a monitored residence. The system does not directly identify which person caused a particular power event.

The controller should therefore assess notice, lawful basis, consent where applicable, and other privacy obligations for all individuals whose activity may be reflected in the monitored data.

If children or other vulnerable individuals are routinely present in the residence, additional legal and safeguarding requirements should be assessed.

### **16. International Processing and Transfers**

The Tuya integration, hosting provider, email provider and WhatsApp provider may process information in countries different from the residence or controller.

**Processing locations and transfer safeguards: [TO BE CONFIRMED]**

The controller should identify the relevant processing locations and document any required transfer mechanism, contractual safeguard, or other legal protection before publication.

### **17. Availability and Limitations**

The system depends on smart-plug connectivity, Tuya Cloud availability, network connectivity, the VPS/server, database availability, and configured notification providers.

A missing or delayed reading can therefore result from a technical/data-availability problem rather than an absence of activity.

The application is designed to distinguish system/data conditions from activity conditions, but no monitoring system can guarantee continuous availability or that every deviation will be detected.

The service should not be treated as a substitute for emergency services, in-person care, medical supervision, or other safety arrangements.

### **18. Changes to This Policy**

This policy should be updated when the application materially changes its data sources, inference methods, user roles, notification channels, third-party providers, hosting architecture, or other processing activities.

**Last updated:** [DATE]

## 19. Contact

- **Organisation:** [LEGAL NAME]
- **Privacy email:** [PRIVACY EMAIL]
- **Address:** [ADDRESS]
- **DPO / privacy contact:** [IF APPLICABLE]

## 20. Implementation Notes for Legal Review

The following points are intended to give legal counsel a precise view of the current implementation:

- Smart plugs are queried through the Tuya Cloud API.
- The collector normally polls approximately every 60 seconds.
- PostgreSQL stores raw telemetry and operational records.
- Readings include timestamp, power, current, voltage, energy increment, switch state and device online status.
- Device records include Tuya device ID, name, room, connectivity state and accumulated energy.
- Confirmed connectivity transitions are stored as events.
- Short connectivity failures are not immediately treated as confirmed outages; the offline tolerance is configurable and defaults to 20 minutes.
- The dashboard has a configurable data-staleness threshold and can show SYSTEM / no-data rather than calculating an activity verdict from stale data.
- Activity inference is derived from power readings and per-device thresholds.
- Activity data gaps are excluded from baseline learning.
- Low-signal devices can be excluded from activity inference while remaining monitored for connectivity.
- The current implementation does not guarantee a fixed minimum number of learning days before showing every inference.
- The dashboard requires authentication.
- Caregiver access is scoped to a residence; administrators have broader settings access.
- Passwords are bcrypt-hashed.
- Sessions are server-side and documented to expire after one week.
- Alert contacts can contain names, email addresses and WhatsApp numbers.
- The alerting service runs periodically and is designed to notify on state changes rather than repeatedly notifying a stable state.
- YELLOW and return-to-GREEN routine states use email for configured all-tier contacts.
- RED activity and SYSTEM/offline conditions use WhatsApp and email for configured contacts when those channels are configured.
- Email notifications use SMTP.
- WhatsApp notifications use a configured external API/provider.
- The current application has no camera, microphone, GPS, physiological-sensor or facial-recognition subsystem.
- The system generates activity/routine inferences but does not itself perform medical diagnosis.
- The documented deployment keeps PostgreSQL bound to localhost.
- The current implementation does not define a complete automatic retention/deletion schedule.

- The current implementation does not itself determine the legal basis for processing.

## 21. Pre-Launch Legal and Operational Checklist

- ☐ Controller legal name completed.
- ☐ Privacy contact completed.
- ☐ Applicable jurisdiction identified.
- ☐ Legal basis confirmed.
- ☐ Assessment of inferred wellbeing/behaviour data completed.
- ☐ Tuya terms, privacy documentation and data-processing arrangements reviewed.
- ☐ SMTP provider identified and reviewed.
- ☐ WhatsApp provider identified and reviewed.
- ☐ Hosting provider identified and reviewed.
- ☐ Processing locations and international transfers assessed.
- ☐ Retention periods defined.
- ☐ Deletion/anonymisation procedure defined.
- ☐ Data-subject request procedure defined.
- ☐ Security controls reviewed for the actual production VPS.
- ☐ HTTPS confirmed for production access.
- ☐ Backup retention and access controls addressed.
- ☐ Automated processing/profiling assessment completed.
- ☐ Household-member notice/consent requirements assessed.
- ☐ Notification wording and emergency limitations reviewed.
- ☐ Final document reviewed and approved by qualified legal counsel.
- ☐ Effective date added before publication.

## Disclaimer

This is an implementation-based technical draft intended to help the service operator and legal counsel understand the application's current data flows and processing activities.

It is **not legal advice** and should not be published as the final Privacy Policy without review and approval by qualified legal counsel.